

NAME: Ayush Mistry

ASSIGNMENT NO. 3

VULNERABILITY ANALYSIS

AIM: To conduct a comprehensive vulnerability assessment of the web application **www.goodshopping.com** using the Nikto scanner, identifying potential security weaknesses and misconfigurations. The goal is to analyze the scan results to understand the specific risks to the financial institution's sensitive data. Finally, to provide clear, actionable recommendations for remediation, thereby enhancing the application's security posture and ensuring robust protection against cyber threats.

TARGET: www.goodshopping.com (IP Address: 15.197.148.33)

TOOL USED: Nikto

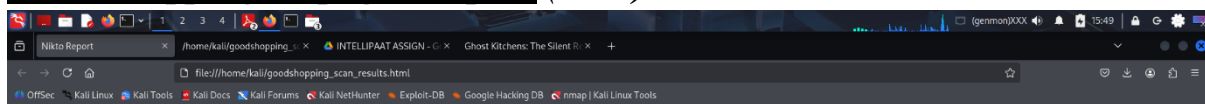
TASK:

1. Scan the Web Application:

Command: nikto -h www.goodshopping.com -o goodshopping_result.txt -f html

- -h: flag specifies target host
- -o: Specifies to save output
- -f: set output format here it is html

GoodsShopping-40 page-Output: (Link)



www.goodshopping.com / 3.33.130.190 port 80	
Target IP	3.33.130.190
Target hostname	www.goodshopping.com
Target Port	80
HTTP Server	
Site Link (Name)	http://www.goodshopping.com:80/
Site Link (IP)	http://3.33.130.190:80/
URI	/
HTTP Method	GET
Description	/: The anti-clickjacking X-Frame-Options header is not present.
Test Links	http://www.goodshopping.com:80/ http://3.33.130.190:80/
References	https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
URI	/
HTTP Method	GET
Description	/: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
Test Links	http://www.goodshopping.com:80/ http://3.33.130.190:80/
References	https://www.netoarker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
URI	/backup.war
HTTP Method	HEAD
Description	/backup.war: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/backup.war http://3.33.130.190:80/backup.war
References	https://cwe.mitre.org/data/definitions/530.html
URI	/com.war
HTTP Method	HEAD
Description	/com.war: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/com.war http://3.33.130.190:80/com.war
References	https://cwe.mitre.org/data/definitions/530.html
URI	/wwwgoodshopping.com.js
HTTP Method	HEAD

Test Links	http://www.goodshopping.com:80/backup.tar.bz2 http://3.33.130.190:80/backup.tar.bz2 https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/dump.egg
HTTP Method	HEAD
Description	/dump.egg: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/dump.egg http://3.33.130.190:80/dump.egg https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/goodshopping.tar
HTTP Method	HEAD
Description	/goodshopping.tar: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/goodshopping.tar http://3.33.130.190:80/goodshopping.tar https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/database.tar
HTTP Method	HEAD
Description	/database.tar: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/database.tar http://3.33.130.190:80/database.tar https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www.goodshopping.com.tar.lzma
HTTP Method	HEAD
Description	/www.goodshopping.com.tar.lzma: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/www.goodshopping.com.tar.lzma http://3.33.130.190:80/www.goodshopping.com.tar.lzma https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www.goodshopping.com.war
HTTP Method	HEAD
Description	/www.goodshopping.com.war: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/www.goodshopping.com.war http://3.33.130.190:80/www.goodshopping.com.war https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/com.jks
HTTP Method	HEAD
Description	/com.jks: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/com.jks http://3.33.130.190:80/com.jks https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www.goodshopping.com.jks
HTTP Method	HEAD
Description	/www.goodshopping.com.jks: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/www.goodshopping.com.jks http://3.33.130.190:80/www.goodshopping.com.jks https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www.tar.lzma
HTTP Method	HEAD
Description	/www.tar.lzma: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/www.tar.lzma http://3.33.130.190:80/www.tar.lzma https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www_goodshopping_com.pem
HTTP Method	HEAD
Description	/www_goodshopping_com.pem: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/www_goodshopping_com.pem http://3.33.130.190:80/www_goodshopping_com.pem https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www.goodshopping.egg
HTTP Method	HEAD
Description	/www.goodshopping.egg: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/www.goodshopping.egg http://3.33.130.190:80/www.goodshopping.egg https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/goodshopping.com.jks
HTTP Method	HEAD
Description	/goodshopping.com.jks: Potentially interesting backup/cert file found. .
Test Links	http://www.goodshopping.com:80/goodshopping.com.jks http://3.33.130.190:80/goodshopping.com.jks https://cwe.mitre.org/data/definitions/530.html
References	https://cwe.mitre.org/data/definitions/530.html
URI	/www.egg
HTTP Method	HEAD
Description	/www.egg: Potentially interesting backup/cert file found. .
Test Links	http://www.egg

To refer more images, click on link: **[GoodsShopping-40 page-Output: \(Link\)](#)**

2. Analyze Nikto Scan Results:

The scan uncovered 220 potential issues.

A. Dangerous Backup Files (Critical)

- Nikto found dozens of files that should never be publicly accessible.
- **Backup Archives:** backup.war, database.tar, dump.tar.bz2, [www.tar.lzma](#), goodshopping.tar, archive.tgz, etc.
- **Private Keys & Certificates:** www.goodshopping.jks, goodshopping.com.pem, www.cer, site.jks, database.jks, etc.
- **Application Code:** .war, .egg files (which are essentially the entire website or application package).
- These files likely contain entire website code, database dumps, or private encryption keys. If a hacker gets these, they can steal customer data, take over the server, or impersonate site.
- An attacker can simply download these files in seconds.

- Backup files likely contain your entire database, including customer names, addresses, credit card numbers, and transaction history.
- Private keys (.jks, .pem) allow an attacker to impersonate your website, intercept secure traffic, or gain full administrative control over the server.
- This is a direct, immediate threat to the financial institution's data and reputation.

B. Known Exploitable Vulnerabilities(High)

- The scan also identified specific, known vulnerabilities in software that might be running on the server.
- Oracle Reports Vulnerability (/reports/rwservlet?server=repsserv...): This could allow an attacker to execute malicious code on the server.
- Example: Exploit-DB 26006.
- BEA WebLogic Takeover (/_async/AsyncResponseServiceJms?WSDL): This is critical, well-known exploit (CVE-2019-2725) that can give an attacker full control of the server.
- SQL Injection (/acart2_0/admin/category.asp?catcode='): Indicates that the website's code is vulnerable to SQL injection, which can lead to database theft or corruption.

C. Security Headers Missing (Medium)

The scan found that the site is missing crucial security headers:

- The site is missing the X-Frame-Options header, making it vulnerable to “clickjacking” attacks (where a user is tricked into clicking something on your site while thinking they are on another site).
- The site is missing the X-Content-Type-Options header, which can allow browsers to misinterpret file types, leading to certain types of injection attacks.

D. Information Leakage & Miscellaneous(low)

- The **sitemap.xml** file gives attackers a perfect map of your entire website.
- Various administrative or debug pages for software like SharePoint (/_layouts/) and Oracle (/pls/portal/) are accessible, potentially revealing internal structure or versions.
- A guestbook page (/guestbook/) is vulnerable to Cross-Site Scripting (XSS), which could be used to target users.

3. Provide Recommendations:

Based on the Nikto scan, www.goodshopping.com is critically exposed. The following recommendations are prioritized by severity and ease of implementation.

A. Clean Unnecessary Information

- Dozens of backup files, private keys, and certificates are publicly accessible.
- Have the server administrator immediately delete all the files listed in the scan from the web server's public directory (e.g., /var/www/html/).
- This includes:
All .war, .tar, .tar.bz2, .tar.lzma, .tgz, .alz, .egg files (e.g., backup.war, database.tar, www.tar.lzma).
All .jks, .pem, .cer files (e.g., www.goodshopping.jks, goodshopping.com.pem, www.cer).
- If these files are legitimate backups, they must be moved to a secure, non-web-accessible location on the server (e.g., /home/backups/) or to a dedicated, secured backup server.

- Private keys (.jks, .pem) were exposed, assuming they might be compromised. Immediately revoke and regenerate all SSL/TLS certificates and server keys.

B. Patch Critical Vulnerabilities

- The server is running software with known vulnerabilities that can be exploited which can lead to complete system takeover.

- **Patch WebLogic Server (CVE-2019-2725):**

The endpoint `/_async/AsyncResponseServiceJms?WSDL` confirms a critical, vulnerability. Apply the official security patch from Oracle for CVE-2019-2725. If patching is not immediately possible, disable or remove the vulnerable AsyncResponseService component.

- **Patch Oracle Reports:**

The endpoint `/reports/rwservlet?server=reperv...` which indicates a vulnerability that allows malicious code execution. Apply the latest security patches for Oracle Reports or, if no patch is available, disable the rwservlet until it can be secured.

- **Fix SQL Injection:**

The shopping cart at `/acart2_0/admin/category.asp?catcode=` is vulnerable to SQL injection. Clean all user inputs in the category.asp script. To stop attackers from sneaking in harmful SQL commands, make sure your code uses parameterized queries or prepared statements. This way, any user input is treated as data, not as part of the SQL command, so even if someone tries to inject malicious code, it will not run. Also upgrading or replacing the “A-Card 2.0” software, as it is known to be insecure.

CONCLUSION:

This assignment was all about finding Vulnerabilities in a website before any hacker Exploit it. Using tool like Nikto to scan, revealing critical oversight. The Alarming discovery was finding tons of backup files and private keys was available there for anyone to download. Additionally, the scan found some old known security vulnerabilities in software like WebLogic and Oracle Reports, which are prime targets for attackers seeking full system control. Even foundational protections, like basic HTTP security headers, were missing, making the site an easier target for common client-side attacks. The good news is, every single problem found has a fix. The path forward is to fix: removal of all exposed files, patching of critical software vulnerabilities, and implementation of basic security improvement measures. Doing this kind of check regularly is the best way to stay safe, because waiting for an attack to happen is never a good plan.